



PRAXISLEITFADEN FÜR KMU

Datenschutz Folgenabschätzung. Pflicht oder nicht? In 10 Minuten wissen Sie es.

Mit der **Prüfreihefolge nach DSFA V und DSFA AV**, den neun Kriterien mit Beispielen aus dem Betriebsalltag, einer Risikomatrix und dem **Schnelltest zum Ankreuzen**.

VORWORT

Klarheit, bevor Ihr Projekt startet.

Sie führen eine Zeiterfassung per Fingerabdruck ein? Ihr Webshop soll Kundenanfragen mit KI beantworten? Ihre Firmenfahrzeuge bekommen GPS Ortung?

Dann stellt sich eine Frage, die viele Betriebe zu spät stellen: Brauchen wir dafür eine Datenschutz Folgenabschätzung, kurz DSFA?

Dieser Leitfaden gibt Ihnen in zehn Minuten eine belastbare erste Antwort. Er ist auf österreichisches Recht zugeschnitten und arbeitet mit den beiden Verordnungen der österreichischen Datenschutzbehörde, die viele Vorlagen aus Deutschland nicht kennen.

Sie sehen, wie Sie prüfen, wie eine DSFA abläuft, wie Sie Risiken bewerten und welche Fehler Sie sich sparen können. Am Ende wartet ein Schnelltest mit zehn Fragen zum Ankreuzen.

Mein Ziel: Sie entscheiden schneller, starten sicherer und haben einen Nachweis in der Hand, falls die Behörde fragt.

Alexander Kroes

Externer Datenschutzbeauftragter · Datenschutz Kroes

DREI FAKTEN VORAB

01

Prüfen vor dem Start

Die DSFA erfolgt vor Beginn der Verarbeitung. Nachträglich ist sie bereits ein Versäumnis. Art. 35 Abs. 1 DSGVO

10 Mio.

Euro Strafraumen

Eine fehlende oder mangelhafte DSFA kann mit bis zu 10 Mio. Euro oder 2 % des weltweiten Jahresumsatzes geahndet werden. Art. 83 Abs. 4 DSGVO

03

Auch ein Nein gehört aufs Papier

Kommen Sie zum Ergebnis, dass keine DSFA nötig ist, halten Sie die Begründung schriftlich fest. Das ist Ihr Nachweis. Art. 5 Abs. 2 DSGVO

SCHRITT 1

Brauche ich eine DSFA?

Die Prüfung in Österreich.

Die österreichische Datenschutzbehörde hat zwei Verordnungen erlassen: eine Ausnahmeliste und eine Muss Liste. Prüfen Sie in dieser Reihenfolge, das spart Ihnen Arbeit.

1

Ausnahmeliste prüfen

TRIFFT ZU: KEINE DSFA

Fällt Ihre Verarbeitung genau unter einen der Standardfälle, etwa klassische Kunden oder Personalverwaltung, und halten Sie die dort genannten Bedingungen vollständig ein? Dann ist keine DSFA nötig. Schon eine Abweichung, etwa zusätzliche Datenarten, hebt die Ausnahme auf.
DSFA AV, BGBl. II Nr. 108/2018, Anlage 1

2

Muss Liste prüfen

TRIFFT ZU: DSFA PFLICHT

Steht Ihre Verarbeitung dort, etwa Profilbildung mit spürbaren Folgen für Betroffene, der Einsatz neuer Technologien wie KI oder Biometrie, bestimmte Formen der Videoüberwachung oder das Zusammenführen von Daten für algorithmische Entscheidungen?
DSFA V, BGBl. II Nr. 278/2018, § 2

3

Gesetzliche Regelfälle

TRIFFT ZU: DSFA PFLICHT

Systematische Bewertung von Personen mit Rechtswirkung, umfangreiche Verarbeitung von Gesundheits oder anderen besonderen Daten sowie Daten über Straftaten, systematische umfangreiche Überwachung öffentlich zugänglicher Bereiche.
Art. 35 Abs. 3 DSGVO

4

Neun Kriterien des Europäischen Datenschutzausschusses

Treffen zwei oder mehr Kriterien zu, ist eine DSFA in der Regel erforderlich. Im Einzelfall reicht bereits eines. Die Kriterien mit Beispielen finden Sie auf der nächsten Seite.
Leitlinien WP 248 rev.01

5

Gesamtbewertung

Bleibt nach Art, Umfang, Umständen und Zweck voraussichtlich ein hohes Risiko für die Betroffenen? Dann führen Sie die DSFA durch. Im Zweifel entscheiden Sie begründet und dokumentiert.
Art. 35 Abs. 1 DSGVO

KUNDEN IN BAYERN?

Unterliegt der Betrieb einer deutschen Aufsichtsbehörde, gilt statt der österreichischen Muss Liste in der Regel die Liste der Datenschutzkonferenz (DSK).

WO FINDE ICH DIE LISTEN?

Beide Verordnungen stehen kostenlos im Rechtsinformationssystem des Bundes: ris.bka.gv.at. Suchbegriffe: DSFA V und DSFA AV.

DIE NEUN KRITERIEN

So sehen die Kriterien im Betriebsalltag aus.

Zählen Sie, wie viele Kriterien auf Ihr Vorhaben zutreffen. Die Beispiele zeigen, wie schnell das auch in kleinen Betrieben passiert.

1**Bewerten oder Scoring von Personen**

BEISPIEL

Bonitätsprüfung vor dem Ratenkauf im Webshop.

2**Automatisierte Entscheidung mit spürbarer Wirkung**

BEISPIEL

Eine Software sortiert Bewerbungen ohne menschliche Prüfung aus.

3**Systematische Überwachung**

BEISPIEL

GPS Ortung der Firmenfahrzeuge, Videoüberwachung im Verkaufsraum.

4**Sensible oder höchstpersönliche Daten**

BEISPIEL

Befunde in der Physiotherapie, Krankenstandsdaten in der Lohnverrechnung.

5**Verarbeitung in großem Umfang**

BEISPIEL

Gästedatenbank eines Hotels mit zehntausenden Einträgen.

6**Zusammenführen von Datensätzen**

BEISPIEL

Webshop, Newsletter und Kassensystem werden zu Kundenprofilen verknüpft.

7**Schutzbedürftige Personen**

BEISPIEL

Beschäftigte, Kinder, Patientinnen und Patienten, Pflegebedürftige.

8**Neue Technologien**

BEISPIEL

KI Chatbot im Kundendienst, Zeiterfassung per Fingerabdruck.

9**Hindert an Rechten oder Leistungen**

BEISPIEL

Ablehnung eines Vertrags oder Zugangs auf Basis einer Datenauswertung.

2 oder mehr Treffer

DSFA ist in der Regel Pflicht. Planen Sie sie vor dem Projektstart ein.

1 Treffer

Genau hinschauen, Ausnahmeliste und Muss Liste prüfen, Entscheidung begründet dokumentieren.

Hinweis: Beschäftigte gelten nach den Leitlinien wegen des Abhängigkeitsverhältnisses als schutzbedürftig. Viele Projekte rund um Personal erfüllen Kriterium 7 daher automatisch.

SCHRITT 2

So läuft eine DSFA ab. In vier Phasen.

Der Inhalt einer DSFA ist gesetzlich vorgegeben. Mit dieser Struktur liefern Sie alles, was die Behörde erwartet.

PHASE 1 Vorbereiten

- Umfang klar abgrenzen: Was genau wird geprüft?
- Zuständige festlegen, Datenschutzbeauftragten einbinden
- Unterlagen sammeln: Produktbeschreibung, Auftragsverarbeitungsvertrag, Berechtigungen

PHASE 2 Beschreiben

- Zwecke und Rechtsgrundlage
- Betroffene Personen und Datenarten
- Empfänger, Drittländer, Speicherdauer und Löschung

Art. 35 Abs. 7 lit. a DSGVO

PHASE 3 Bewerten

- Notwendigkeit und Verhältnismäßigkeit: Gibt es ein milderer Mittel?
- Risiken für die Betroffenen einschätzen
- Technische und organisatorische Maßnahmen festlegen

Art. 35 Abs. 7 lit. b bis d DSGVO

PHASE 4 Abschließen

- Restrisiko bewerten, Freigabe durch die Geschäftsführung
- Bleibt das Risiko hoch: vorherige Konsultation der Datenschutzbehörde
- Wiedervorlage festlegen, bei Änderungen erneut prüfen

Art. 36 und Art. 35 Abs. 11 DSGVO

PRAXISBEISPIEL

Ein Hotel mit 40 Beschäftigten will die Arbeitszeit per Fingerabdruck erfassen. Biometrie als neue Technologie und Beschäftigte als schutzbedürftige Gruppe: zwei Kriterien, dazu steht Biometrie auf der Muss Liste. Die DSFA ist Pflicht. In Phase 3 zeigt sich oft: Chip oder App erfüllen den Zweck genauso. Dann scheitert der Fingerabdruck an der Verhältnismäßigkeit. Diese Erkenntnis vor dem Kauf spart Geld und Ärger.

ROLLE DES DATENSCHUTZBEAUFTRAGTEN

Sie als Verantwortlicher führen die DSFA durch. Ihr Datenschutzbeauftragter berät und überwacht. Holen Sie ihn so früh wie möglich dazu. Art. 35 Abs. 2, Art. 39 Abs. 1 lit. c DSGVO

ARBEITSRECHT MITDENKEN

Kontrollsysteme brauchen oft eine Betriebsvereinbarung. Ohne Betriebsrat ist bei Maßnahmen, die die Menschenwürde berühren, die Zustimmung der Beschäftigten nötig. §§ 96, 96a ArbVG, § 10 AVRAG

SCHRITT 3

Risiken bewerten. Mit einer einfachen Matrix.

Bewerten Sie jedes Risiko nach Wahrscheinlichkeit (W) und Schwere des möglichen Schadens für die Betroffenen (S), jeweils von 1 bis 4. Das Produkt ergibt den Risikowert.

Schwere ↓ · Wahrscheinlichkeit →	1 gering	2 begrenzt	3 erheblich	4 hoch
4 sehr schwer	4	8	12	16
3 schwer	3	6	9	12
2 spürbar	2	4	6	8
1 gering	1	2	3	4

1 bis 3 niedrig
4 bis 6 mittel
8 bis 16 hoch

Erst brutto, dann netto. Bewerten Sie zuerst ohne Schutzmaßnahmen. Danach legen Sie Maßnahmen fest und bewerten erneut.

Rot nach Maßnahmen? Dann müssen Sie vor dem Start die Datenschutzbehörde konsultieren. Besser: weitere Maßnahmen oder ein milderes Mittel wählen.

WORAN SIE RISIKEN FESTMACHEN

Vertraulichkeit. Kein Zugriff durch Unbefugte.

Integrität. Daten bleiben richtig und unverändert.

Verfügbarkeit. Daten sind da, wenn sie gebraucht werden.

Datenminimierung. Nur so viele Daten wie nötig.

Transparenz. Betroffene wissen, was mit ihren Daten passiert.

Intervenierbarkeit. Betroffene können ihre Rechte ausüben.

Nichtverkettung. Keine Nutzung über den Zweck hinaus.

Grundlage: Standard Datenschutzmodell, auch in Österreich eine bewährte Orientierung.

KOSTENLOSE VORLAGE

Die Risikomatrix gibt es als Excel Vorlage: Risikowert und Ampel berechnen sich automatisch, vorher und nachher. Anfordern unter info@datenschutz-kroes.at, Betreff: Risikomatrix.

SCHRITT 4

Fünf Fehler, die ich in KMU immer wieder sehe.

Die meisten Probleme entstehen nicht in der Risikoanalyse, sondern davor und danach. So vermeiden Sie sie.

1 Die Prüfung kommt nach dem Kauf

Der Vertrag mit dem Softwareanbieter ist unterschrieben, dann erst wird gefragt, ob das zulässig ist.

Besser: Vor der Kaufentscheidung prüfen. Das Ergebnis stärkt Ihre Position in der Vertragsverhandlung.

2 Die Muster DSFA des Herstellers wird übernommen

Anbieter liefern gern fertige Dokumente. Die Verantwortung für Ihren Einsatz, Ihre Daten und Ihre Risiken bleibt aber bei Ihnen.

Besser: Als Grundlage nutzen und auf Ihren Betrieb anpassen.

3 Kein Nachweis für das Nein

Man hat geprüft und entschieden, dass keine DSFA nötig ist. Aufgeschrieben hat es niemand.

Besser: Kurzvermerk mit Datum, Prüfschritten und Ergebnis. Eine halbe Seite genügt.

4 Einmal gemacht, nie wieder angesehen

Neue Funktionen, neue Datenarten, ein neuer Anbieter. Die DSFA bleibt auf dem alten Stand.

Besser: Wiedervorlage im Kalender, bei jeder wesentlichen Änderung und mindestens jährlich prüfen.

5 Das Arbeitsrecht wird vergessen

Die DSFA ist sauber, aber Betriebsrat oder Beschäftigte wurden nicht eingebunden. Das System darf trotzdem nicht laufen.

Besser: Betriebsvereinbarung oder Zustimmung parallel zur DSFA vorbereiten.

MEIN FAZIT

Eine gute DSFA bremst nicht. Sie zeigt, wie Ihr Projekt sicher startet, und liefert Ihnen die Argumente gegenüber Behörde, Betriebsrat und Kunden.

SCHNELLTEST ZUM ANKREUZEN

Brauchen Sie eine DSFA?

Zehn Fragen, eine klare Richtung.

01	Setzen Sie biometrische Verfahren ein, etwa Fingerabdruck oder Gesichtserkennung für Zutritt oder Zeiterfassung?	☐ ja ☐ nein
02	Orten Sie Beschäftigte oder Fahrzeuge per GPS oder App?	☐ ja ☐ nein
03	Überwachen Sie per Video Bereiche, in denen sich Kunden, Gäste oder Passanten aufhalten?	☐ ja ☐ nein
04	Nutzen Sie KI, die Anfragen, Bewerbungen oder Kundendaten automatisch auswertet oder beantwortet?	☐ ja ☐ nein
05	Trifft oder bereitet eine Software Entscheidungen über Personen vor, etwa zu Bonität oder Bewerberauswahl?	☐ ja ☐ nein
06	Verarbeiten Sie Gesundheitsdaten oder andere besonders sensible Daten in größerem Umfang?	☐ ja ☐ nein
07	Führen Sie Daten aus mehreren Systemen zu Profilen zusammen, etwa Webshop, Newsletter und Kasse?	☐ ja ☐ nein
08	Werten Sie das Verhalten Ihrer Beschäftigten systematisch aus, etwa Internetnutzung oder Leistung?	☐ ja ☐ nein
09	Verarbeiten Sie Daten von Kindern, Patienten oder Pflegebedürftigen in größerem Umfang?	☐ ja ☐ nein
10	Verwalten Sie Daten von mehreren tausend Personen, etwa Kunden, Gästen oder Mitgliedern?	☐ ja ☐ nein

Kein Ja

Eine DSFA ist wahrscheinlich nicht nötig. Halten Sie die Prüfung trotzdem kurz schriftlich fest.

Ein Ja

Prüfen Sie Ausnahmeliste, Muss Liste und die neun Kriterien genau. Entscheidung dokumentieren.

Zwei oder mehr

Eine DSFA ist sehr wahrscheinlich Pflicht. Klären Sie den Ablauf vor dem Projektstart.

Der Schnelltest ersetzt keine vollständige Prüfung im Einzelfall. Er zeigt Ihnen, wo Sie genauer hinsehen sollten.

UNTERSTÜTZUNG

Damit Ihr Projekt sicher startet.

Als externer Datenschutzbeauftragter begleite ich Betriebe in Tirol, Salzburg und Bayern von der ersten Prüfung bis zur fertigen Dokumentation. Sie erhalten eine klare Antwort, eine schlanke Dokumentation und Maßnahmen, die im Alltag funktionieren.

01

Schnell entscheiden

Sie wissen, ob Sie eine DSFA brauchen, bevor Sie Geld in ein System investieren.

02

Prüfungssicher dokumentieren

Eine DSFA, die Behörde und Betriebsrat überzeugt, ohne Papierberg.

03

Persönlich erreichbar

Ein fester Ansprechpartner, der Ihren Betrieb kennt.

KOSTENLOS · 30 MINUTEN · UNVERBINDLICH

Ihr Erstgespräch zur DSFA

Sie schildern Ihr Vorhaben, ich gebe Ihnen eine erste Einschätzung zu Pflicht und Aufwand.

Termin vereinbaren >



Alexander Kroes

Externer Datenschutzbeauftragter

E MAIL

info@datenschutz-kroes.at

WEB

[datenschutz-kroes.at](https://www.datenschutz-kroes.at)